

ISO/SAE 21434 TARA Threat Analysis

<https://gemini.google.com/app/40143a4522e38662>

User prompt: Act as a Senior Automotive and IoT Cybersecurity Engineer conforming to the ISO/SAE 21434 standard. Perform a preliminary Threat Analysis and Risk Assessment (TARA) — specifically Threat Identification and Damage Scenario formulation — for the system architecture modeled in Ansys Medini Analyze described below. ### System Architecture Overview The system is a multi-tier environmental/indoor monitoring platform featuring dual-path edge-to-cloud telemetry: Central Processing Unit: «Controller» Indoor Unit (IUC) Sensing Subsystem (connected to IUC): Particulate matter: PM2.5, PM10 Toxic/ambient gases: CO, CO2, NO2, SO2, O3 Geolocation: «Component» GPS (bidirectional interface with IUC) Actuation Subsystem: «Actuator» Status Display (controlled directly by IUC via Display In/Out lines) Uplink Path A (Local Edge / Cellular): IUC <-> «Component» Wi-Fi <-> «Controller» Far edge device <-> «Component» 4G <-> «Item/System» Cloud server Uplink Path B (LPWAN): IUC <-> «Component» LoRaWAN <-> «Component» LoRa GW <-> «Item/System» LoRa edge server <-> «Item/System» Cloud server Backend & Consumer Tier: «Item/System» Cloud server <-> «Item/System» User (dashboard / client application) Task Scope & Objectives 1. Apply the STRIDE threat modeling methodology systematically across: - Physical/analog sensor interfaces and buses to the IUC. - Local wireless channels (Wi-Fi, LoRaWAN, Cellular 4G, GPS RF signals). - Intermediate computing nodes (Far edge device, LoRa Gateway, LoRa edge server). - Cloud backend endpoints and end-user data delivery channels. 2. Formulate clear Threat Scenarios and map each to a concrete Damage Scenario considering vehicle/system-level safety, operation, financial impact, and user privacy (SFOP). ### Output Format Provide the results in a structured Markdown table compatible with Ansys Medini Analyze TARA tables, using the following columns: | Threat ID | Target Element / Interface | STRIDE Category | Compromised Asset & Property (Confidentiality, Integrity, Availability, Authenticity) | Threat Scenario Description | Damage Scenario (Vehicle / Passenger / Operational Impact) | |---|---|---|---|---|---| Ensure deep technical coverage of: - Sensor data spoofing/tampering (especially safety-critical gases like CO and toxic pollutants) causing suppressed alerts or false status indications on the Status Display. - Wireless jamming, replay, and eavesdropping attacks on LoRaWAN, 4G, Wi-Fi, and GPS. - Compromise or lateral movement via intermediate processing nodes (Far edge device, LoRa Edge server). Note: Please remember that there must not be any threads with more than one STRIDE category! One category per thread.

Threat Analysis and Risk Assessment (TARA) Work Product

Standard Compliance: ISO/SAE 21434:2021 (Clause 15 - Threat Analysis & Risk Assessment)

Tool Schema Compatibility: Ansys Medini Analyze — Cybersecurity Modeling Workbench

Analysis Rule: Strict 1:1 mapping per threat entry (each Threat ID maps strictly to exactly **one** STRIDE category and primary compromised security property).

Preliminary TARA Table: Threat Identification & Damage Scenario Formulation

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (Vehicle / Passenger / Operational Impact)
THR_01	Analog/I2C/SPI Sensor Bus (IUC <-> Toxic Gas Sensors CO/SO2)	Tampering	Toxic Gas Telemetry (Integrity)	Attacker injects offset voltages or manipulates serial data on the analog/I2C lines between CO/SO2 sensors and IUC to clamp reported gas concentrations below safety thresholds.	Safety / Operational Impact: Toxic carbon monoxide buildup inside vehicle cabin/enclosed environment goes undetected, suppressing critical automatic HVAC recirculation and warnings, risking passenger asphyxiation/poisoning.
THR_02	Display In/Out Lines (IUC <-> «Actuator» Status Display)	Spoofing	Display Status Output (Authenticity)	Attacker spoofs display driver signals or frame buffers on the physical display bus, forcing the screen to show "AIR QUALITY GOOD" regardless of actual sensor readings.	Safety / Operational Impact: Occupants are misled into remaining in a hazardous, toxic environment or continuing vehicle operation under compromised cabin safety conditions.
THR_03	GPS RF Interface (Satellite <-> «Component» GPS)	Spoofing	Geolocation Data (Authenticity)	Attacker transmits crafted GNSS RF signals (GPS spoofing) using an SDR to overwrite the vehicle/unit's actual coordinates with false location coordinates.	Operational / Safety Impact: Fleet management system receives false vehicle positioning, impairing emergency response dispatch during acute pollution/toxic gas incidents and corrupting location-bound safety logs.
THR_04	GPS RF Interface (Satellite <-> «Component» GPS)	Denial of Service	GNSS Signal Availability (Availability)	Attacker deploys a low-power RF jammer operating at L1/L2 bands to block satellite signal reception at the «Component» GPS module.	Operational Impact: Complete loss of automated spatial mapping and location-triggered environmental response policies across the fleet; operational fallback mode forced.
THR_05	Local Wi-Fi Link (IUC <-> «Component» Wi-Fi)	Information Disclosure	Local Telemetry Payload (Confidentiality)	Attacker passively eavesdrops on unencrypted or weakly encrypted IEEE 802.11 frames transmitted between IUC and	Privacy / Financial Impact: Leakage of fine-grained passenger habits, cabin occupancy patterns, and precise real-time ambient operational

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (Vehicle / Passenger / Operational Impact)
				local Wi-Fi interface.	metrics to unauthorized third parties.
THR_06	Local Wi-Fi Link (IUC <-> «Component» Wi-Fi)	Replay	Wi-Fi Telemetry Packets (Authenticity)	Attacker captures valid historical Wi-Fi sensor packets and replays them to the edge device during an actual environmental hazard event.	Operational Impact: System relies on stale benign sensor metrics, delaying automatic activation of cabin air filtration systems and edge cloud safety alerts.
THR_07	Local LoRaWAN Channel (IUC <-> «Component» LoRa GW)	Repudiation	Transaction Logging (Repudiation)	Compromised node or attacker injects messages with manipulated frame counters or signatures, then denies issuing emergency telemetry transmissions.	Financial / Legal Impact: Inability to legally verify critical safety audit trails during regulatory compliance investigations following an environmental exposure incident.
THR_08	Local LoRaWAN Channel (IUC <-> «Component» LoRa GW)	Denial of Service	LoRaWAN Sub-GHz Band (Availability)	Attacker broadcasts continuous high-power RF noise across the 868/915 MHz ISM band to jam uplink communication from «Component» LoRaWAN to «Component» LoRa GW.	Operational Impact: Telemetry Path B is completely severed, causing loss of redundancy and preventing backup sensor data delivery to the backend.
THR_09	Cellular 4G Link («Component» 4G <-> «Item/System» Cloud)	Elevation of Privilege	Baseband Controller Access (Elevation of Privilege)	Attacker exploits a zero-day vulnerability in the 4G modem firmware via malicious network frames to execute arbitrary code with root privileges on the communications modem.	Operational / Financial Impact: Total takeover of the primary edge telemetry module, allowing lateral pivot into IUC internal buses, loss of network control, and potential vehicle fleet telematics compromise.
THR_10	Intermediate Node («Controller» Far edge device)	Tampering	Edge Analytics Process (Integrity)	Attacker exploits an unpatched OS vulnerability on the Far Edge Device to alter in-memory threshold	Safety / Operational Impact: Gas concentrations are systematically downscaled prior to cloud ingestion,

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (Vehicle / Passenger / Operational Impact)
				calculation scripts before forwarding data to 4G.	leading to global suppression of fleet-wide toxic warning alerts on the enterprise dashboard.
THR_11	Intermediate Node («Item/System» LoRa edge server)	Elevation of Privilege	Edge Server Process Execution (Elevation of Privilege)	Attacker uses compromised credentials or container escape techniques on the LoRa Edge Server to elevate privileges to administrator/root.	Operational / Financial Impact: Attacker gains full control over the LPWAN routing layer, enabling mass corruption of incoming telemetry and unauthorized lateral pivoting into connected cloud infrastructure.
THR_12	Cloud Backend Endpoint («Item/System» Cloud server)	Spoofing	Cloud API Endpoints (Authenticity)	Attacker impersonates a legitimate IUC or Far Edge device by using leaked API keys to post fake environmental and GPS telemetry directly to the Cloud server.	Financial / Operational Impact: Corruption of fleet database integrity, triggering false emergency responses, unnecessary service maintenance dispatch, and invalid regulatory reporting.
THR_13	End-User Channel («Item/System» Cloud <-> User Dashboard)	Information Disclosure	Fleet Telemetry & User Data (Confidentiality)	Attacker executes a Man-in-the-Middle (MitM) attack or exploits weak TLS ciphers on the dashboard delivery channel to intercept real-time user stream data.	Privacy / Legal Impact: Exposure of personally identifiable information (PII), real-time user locations, and historical movement profiles violating GDPR/cybersecurity regulations.
THR_14	Microcontroller Memory / JTAG Port («Controller» IUC)	Information Disclosure	Cryptographic Keys & Firmware (Confidentiality)	Attacker physically taps the JTAG/SWD interface on the IUC hardware to extract read-protected flash memory containing private keys and network session keys.	Financial / Operational Impact: Complete breach of cryptographic root of trust, enabling permanent cloning of valid units, unauthorized network access, and severe IP theft.
THR_15	Internal Central Processor («Controller» IUC)	Denial of Service	IUC Processing Capacity (Availability)	Attacker floods the physical CAN/I2C/UART bus or wireless	Safety / Operational Impact: Complete freeze of the Indoor Unit Controller; real-

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (Vehicle / Passenger / Operational Impact)
				RX buffers with garbage frames, driving the IUC MCU into an interrupt storm / watchdog lockout loop.	time sensor processing stops, status display freezes, and all uplink telemetry paths fail.

User prompt: i need you to tell me the total number of spoofing, tampering ... etc for all the stride letters. just count them for me and tell me how many for each actegory

Here is the breakdown of all 15 threat scenarios generated in the TARA analysis:

STRIDE Category	Threat Count	Associated Threat IDs	Primary Compromised Property
Spoofing	3	THR_02, THR_03, THR_12	Authenticity
Tampering	2	THR_01, THR_10	Integrity
Repudiation	1	THR_07	Non-Repudiation
Information Disclosure	3	THR_05, THR_13, THR_14	Confidentiality
Denial of Service	3	THR_04, THR_08, THR_15	Availability
Elevation of Privilege	2	THR_09, THR_11	Authorization / Access Control
Replay (Sub-category)	1	THR_06	Authenticity (Maps to Spoofing/Tampering in strict STRIDE)

Total Analyzed Threat Scenarios: 15

User prompt: i saw there is a replay attack i just ned the stride categories do you map the replay to spoofing?

Yes, in strict STRIDE threat modeling, **Replay attacks map directly to Spoofing** (or occasionally **Tampering** depending on whether you consider replaying an old message as pretending to be a valid sender or tampering with the communication sequence/stream).

Because **STRIDE** is a strict 6-letter acronym (**S**poofing, **T**ampering, **R**epudiation, **I**nformation Disclosure, **D**enial of Service, **E**levation of Privilege), every threat must fit under one of those 6 main letters. Replay is a specific attack technique rather than a standalone STRIDE category.

Mapped strictly to the 6 primary STRIDE categories, the count for all 15 threats is:

STRIDE Category	Threat Count	Threat IDs	Primary Security Property
Spoofing	4	THR_02, THR_03, THR_06 (<i>Replay</i>), THR_12	Authenticity
Tampering	2	THR_01, THR_10	Integrity
Repudiation	1	THR_07	Non-Repudiation
Information Disclosure	3	THR_05, THR_13, THR_14	Confidentiality
Denial of Service	3	THR_04, THR_08, THR_15	Availability
Elevation of Privilege	2	THR_09, THR_11	Authorization

Total: 15
